

agentic-ai-azure-week11-security

Week 11 - Enterprise Security & Compliance

Agentic AI on Azure - Enterprise Master Class | Handout (slides + notes)

Notes

Welcome. This deck covers 'agentic-ai-azure-week11-security' - Week 11 - Enterprise Security & Compliance. Frame the problem and why it matters, then walk the class through the learning goal, the enterprise use case, the architecture/flow, the key concepts, a live run in VS Code, and the architect's takeaways. The repo runs locally with no Azure, so demo it live.

Slide 2 - Learning goal

- Secure agents with identity & RBAC
- Enforce least privilege (on-behalf-of)
- Audit every access

Notes

[Learning goal] Walk through these talking points:

- Secure agents with identity & RBAC
- Enforce least privilege (on-behalf-of)
- Audit every access

Ask the class: which of these ideas is new to you?

Slide 3 - Enterprise use case

- HR Self-Service Agent with Least Privilege
- Acts on behalf of the signed-in user
- Only sees data that user is entitled to

Notes

[Enterprise use case] Walk through these talking points:

- HR Self-Service Agent with Least Privilege
- Acts on behalf of the signed-in user
- Only sees data that user is entitled to

Tip: relate this to a regulated scenario your students know.

Slide 4 - Architecture / flow

- Identity: Entra JWT (prod) / dev headers (local)
- Validate signature, audience, issuer, expiry
- Least privilege: manager role to read others, else 403
- Audit log of allowed & denied accesses

Notes

[Architecture / flow] Walk through these talking points:

- Identity: Entra JWT (prod) / dev headers (local)
- Validate signature, audience, issuer, expiry
- Least privilege: manager role to read others, else 403
- Audit log of allowed & denied accesses

Demo: trace a single request through these steps live.

Slide 5 - Key concepts

- Real Entra JWT validation (JWKS, RS256) - verified
- OAuth2 On-Behalf-Of for downstream tools
- Secrets in Key Vault + Managed Identity

Notes

[Key concepts] Walk through these talking points:

- Real Entra JWT validation (JWKS, RS256) - verified
- OAuth2 On-Behalf-Of for downstream tools
- Secrets in Key Vault + Managed Identity

Open the named file in the repo while you explain each point.

Slide 6 - Run it (VS Code - no Azure needed)

- git clone the repo, then open it in VS Code
- python -m venv .venv -> activate it
- pip install -r requirements.txt
- uvicorn app.main:app --reload
- Open /docs and call POST /api/v1/hr/ask
- Runs in MOCK mode - no Azure/keys needed

Notes

[Run it (VS Code - no Azure needed)] Walk through these talking points:

- git clone the repo, then open it in VS Code
- python -m venv .venv -> activate it
- pip install -r requirements.txt
- uvicorn app.main:app --reload
- Open /docs and call POST /api/v1/hr/ask
- Runs in MOCK mode - no Azure/keys needed

Pause for questions before moving on.

Slide 7 - Architect's takeaways

- App vs. user vs. tool identity boundaries
- Prompt-injection & exfiltration defenses
- RBAC + Conditional Access + Purview lineage

Notes

[Architect's takeaways] Walk through these talking points:

- App vs. user vs. tool identity boundaries
- Prompt-injection & exfiltration defenses
- RBAC + Conditional Access + Purview lineage

Discussion: when would you NOT choose this approach?